

README - KIT INTEGRAL DE ENCUESTA DORA+GQM+PRAGMATIC

Guía de Uso y Descripción de Componentes

Versión: 1.0

Fecha: Enero 2026

Clasificación: Profesional — Documentación de Implementación

Audiencia: CISO, CRO, Compliance, Project Managers

BIENVENIDA

Bienvenido a la **Suite Integral GQM+PRAGMATIC para Medición DORA**. Este kit proporciona un framework profesional y exhaustivo para:

- ✓ Medir madurez ciberseguridad conforme DORA (España)
- ✓ Aplicar metodología GQM (Goal-Question-Metric)
- ✓ Evaluar métricas bajo criterios PRAGMATIC (9 dimensiones)
- ✓ Calcular ROI/ROSI de iniciativas seguridad
- ✓ Generar reportes ejecutivos para Junta Directiva
- ✓ Preparar auditoría supervisora (CNMV, Banco de España)

Valor: €200,000+ en servicios consultoría profesional — Ahora descargable.

COMPONENTES DEL KIT

El kit completo contiene **6 documentos complementarios**:

Documento 1: Marco Integrativo GQM + PRAGMATIC

Archivo: Marco-GQM-PRAGMATIC.md

Tamaño: ~45 KB

Duración lectura: 60-90 minutos

Contenido:

- Metodología GQM (3 niveles: Goal → Question → Metric)
- Criterios PRAGMATIC explicados (9 dimensiones)
- Trazabilidad nacional España → datos técnicos (8 niveles)
- Ejemplos detallados de indicadores DORA
- Integración GQM-PRAGMATIC con matriz completa

Para quién:

- CISO/CTO necesitando framework metodológico
- Project managers diseñando programa medición
- Auditors validando trazabilidad requerimientos

Cómo usar:

1. Leer §1-3 (introducción + metodologías)
2. Revisar §5 (ejemplos indicadores)
3. Usar §6 (matriz trazabilidad) como referencia



Documento 2: Matriz Evaluación PRAGMATIC Completa

Archivo: Matriz-Evaluacion-PRAGMATIC.md

Tamaño: ~55 KB

Duración lectura: 45-60 minutos

Contenido:

- Evaluación de **15 indicadores DORA clave**
- Scoring 1-5 para cada uno de **9 criterios PRAGMATIC**
- Justificación detallada de cada score
- Ranking consolidado de indicadores
- Matriz de decisión: implementar sí/no
- Recomendaciones estratégicas por fase (3 fases)
- Presupuesto indicativo (€480-670K, 2 años)

Para quién:

- CRO/CFO tomando decisiones presupuestarias
- CISO priorizando iniciativas seguridad
- Governance boards necesitando justificación inversiones

Cómo usar:

1. Revisar "Resumen Ejecutivo" (top 15 indicadores)
2. Seleccionar indicadores relevantes a institución
3. Usar "Matriz Decisión" para priorizar (Score PRAGMATIC threshold)
4. Planificar fases 1-3 con presupuesto



Documento 3: Mapeo Métricas → Requisitos Normativos

Archivo: Mapeo-Metricas-Normativos.md

Tamaño: ~40 KB

Duración lectura: 45 minutos

Contenido:

- **Matriz trazabilidad:** 15 indicadores — Artículos DORA específicos
- **RTS (Regulatory Technical Standards)** aplicables
- **Requisitos técnicos** detallados por métrica
- **Componentes de medición** (qué data se necesita)
- **Evidencia de cumplimiento** (qué documentar)
- **Benchmarks regulatorios** (Banco de España, CNMV)
- **Supervisory focus** (qué verifican auditors)

Para quién:

- Compliance officers preparando auditoría
- CISO alineando controles con DORA Articles
- Legal/Audit validando cumplimiento normativo

Cómo usar:

1. Seleccionar Artículo DORA de interés
2. Encontrar indicadores mapeados a ese Artículo
3. Recopilar evidencia conforme "Evidencia Cumplimiento"
4. Preparar pack evidencia para supervisores

Ejemplo:

- Supervisor pregunta: "¿Cómo verifican cumplimiento Art. 18 (Detección Incidentes)?"
- Responder: Mostrar Indicador 1 (MTTD), evidencia SIEM dashboard, reportes, logs

Documento 4: Plantilla Excel - IGM y ROI

Archivo: Plantilla-Excel-IGM-ROI.md

Tamaño: ~60 KB

Duración lectura: 90 minutos

Contenido:

- **Hoja 1 - Dashboard IGM:** Cálculo Índice Gestión Madurez (1-5)
- **Hoja 2 - ROI/ROSI:** Análisis financiero inversiones
- **Hoja 3 - ALE Calculation:** Annualized Loss Expectancy por incidente
- **Hoja 4 - Roadmap Inversión:** Presupuesto por fase + timelines
- **Fórmulas específicas** para cada cálculo
- **Ejemplos reales** (SIEM, TLPT, Encryption)
- **Integración PRAGMATIC:** Cómo usar scores en análisis ROI

Para quién:

- CFO/Finance necesitando justificación presupuestaria
- CISO demostrando ROI a Board
- Project managers tracking inversión vs beneficios

Cómo usar (Implementación Excel):

1. Descargar plantilla Excel (descrita en documento)
2. Rellenar Hoja 1: Indicadores actuales × 5 pilares → IGM auto-calcula
3. Rellenar Hoja 3: ALE por tipo incidente
4. Rellenar Hoja 4: Presupuesto iniciativas
5. Sistema auto-genera ROSI, Payback, NPV
6. Exportar Hoja 2 a PowerPoint (gráficos)

Resultado: Dashboard interactivo para presentar a Junta

Documento 5: Plantilla PowerPoint - Reporte Ejecutivo

Archivo: Plantilla-PowerPoint-Reporte.md

Tamaño: ~50 KB

Duración lectura: 60 minutos

Contenido:

- **Estructura 15 slides** lista para personalizar
- **Slide-by-slide guidance:** Contenido, elementos visuales, diseño
- **Radar chart:** IGM consolidado (5 pilares)
- **Detalles por pilar:** Score, indicadores, gaps, acciones
- **Análisis financiero:** ROI/ROSI charts, Payback timeline
- **Roadmap visual:** Gantt chart fases 1-3
- **Risk dashboard:** Riesgos residuales + mitigaciones
- **Design guide:** Paleta colores, tipografía, elementos recurrentes
- **Versiones por audiencia:** Junta (30 min), CRO (45 min), Supervisores (60 min)

Para quién:

- CISO presentando a Junta Directiva
- CRO reportando a Risk Committee
- Compliance officers briefing supervisores

Cómo usar:

1. Abrir PowerPoint (cualquier versión)
2. Crear 15 slides siguiendo estructura
3. Personalizar con datos institución
4. Adaptar duración según audiencia
5. Practicar presentación (~20-30 min)

Ejemplo: Slide 11 muestra ROI; prepare datos excel previo.

Documento 6: README (Este Documento)

Archivo: README-Kit-Encuesta.md

Tamaño: ~40 KB

Duración lectura: 30 minutos

Contenido:

- Overview kit completo
- Guía de uso por rol/audiencia
- Roadmap de implementación (timeline 6 meses)
- FAQ y troubleshooting
- Contacto support

GUÍA POR PERFIL DE USUARIO

Perfil 1: CISO / CTO

Objetivo: Medir madurez ciberseguridad + planificar roadmap

Documentos recomendados:

1. Marco GQM+PRAGMATIC (framework metodológico)
2. Matriz PRAGMATIC (qué indicadores priorizar)
3. Mapeo Normativos (DORA alignment)
4. Excel IGM (medir estado actual)

Timeline recomendado:

- Semana 1: Leer Marco + Matriz (familiarización)
- Semana 2: Mapear indicadores a institución (customización)
- Semana 3: Recopilar datos actuales
- Semana 4: Calcular IGM baseline en Excel
- Semana 5-6: Plantilla PowerPoint → presentar a leadership

Actividades clave:

- ☐ Semana 1: Workshop interno (2h) - explicar GQM/PRAGMATIC
- ☐ Semana 2: Audit actual estado (qué tenemos hoy)
- ☐ Semana 3: Data gathering (SIEM, tickets, scanning reports)
- ☐ Semana 4: IGM calculation + Gap analysis
- ☐ Semana 5: Roadmap design (Fase 1-3)
- ☐ Semana 6: Board presentation (PowerPoint)

Perfil 2: CRO / Risk Officer

Objetivo: Entender riesgos residuales + justificar inversión

Documentos recomendados:

1. Matriz PRAGMATIC (ejecutivo summary: slide 2)
2. Excel IGM+ROI (financials)
3. PowerPoint Reporte (presentación junta)
4. Mapeo Normativos (supervisory compliance)

Timeline recomendado:

- Día 1: Revisar "Resumen Ejecutivo" Matriz PRAGMATIC
- Día 2: Revisar Excel ROI (3 ejemplos: SIEM, TLPT, Encryption)
- Día 3: Revisar PowerPoint estructura
- Día 4: Preparar datos institucionais
- Día 5: Generar reportes Excel
- Semana 2: Present to Junta

Actividades clave:

- ☐ Review PRAGMATIC scores para institución
- ☐ Estimación ALE (breach cost modeling)
- ☐ Presupuesto Fases 1-3 (business case)
- ☐ Risk appetite alignment (¿qué nivel riesgo aceptamos?)
- ☐ Board decision framework

Perfil 3: Compliance / Audit Officer

Objetivo: Validar DORA compliance + preparar auditoría supervisora

Documentos recomendados:

1. Mapeo Normativos (DORA Article → evidencia)
2. Marco GQM+PRAGMATIC (methodology rigor)
3. Excel IGM (score vs benchmarks)
4. PowerPoint Reporte (supervisory readiness)

Timeline recomendado:

- Fase 1 (Enero): Revisar Mapeo Normativos + crear compliance matrix
- Fase 2 (Feb): Recopilar evidencia por Artículo DORA
- Fase 3 (Mar-Abr): Audit interno (GAP analysis)
- Fase 4 (May-Jun): Remediation tracking
- Fase 5 (Jul-Ago): Supervisory prep

Actividades clave:

- ☐ Map institución a Mapeo Normativos (15 indicadores)
- ☐ Crear evidencia checklist per Artículo
- ☐ Recopilar documentación (policies, logs, tickets)
- ☐ Gap analysis: qué falta
- ☐ Remediation plan con timelines
- ☐ Mock audit (interno antes de supervisor)
- ☐ Supervisory presentation pack (documentos + evidencia)

Perfil 4: Finance / CFO

Objetivo: Aprobar presupuesto ciberseguridad; asegurar ROI

Documentos recomendados:

1. Excel IGM+ROI (financial analysis)
2. PowerPoint Reporte (Slide 11: ROI/ROSI; Slide 12: Roadmap)
3. Matriz PRAGMATIC (Slide "Recomendaciones")

Timeline recomendado:

- Day 1: Revisar Excel ROI (30 min)
- Day 2: Q&A con CISO (30 min)
- Day 3: Revisar PowerPoint Slides 11-13
- Day 4: Decision

Actividades clave:

- ☐ Validate ALE assumptions (cost breach = €2.3M?)
- ☐ Confirm payback timelines (6.5 meses avg)
- ☐ Review cash flow impact (setup vs operational)
- ☐ Approve Fase 1 presupuesto (€460K) ← CRITICAL
- ☐ Schedule budget review Q2-Q3

Preguntas Finance hará:

- "¿Cuál es payback period?" → Excel sheet responde (6.5 meses avg)
- "¿Es ROI positivo?" → PowerPoint Slide 11 muestra 203% ROSI
- "¿Cuándo vemos resultados?" → Roadmap Slide 12 tiene timeline
- "¿Qué si fallamos?" → Risk Dashboard Slide 14 explica mitigación

Perfil 5: Board / Junta Directiva

Objetivo: Supervisión gobernanza; aprobación inversión

Documentos recomendados:

1. PowerPoint Reporte (Slides 1, 2, 4, 11, 13, 15)
2. Excel IGM+ROI (summary table)
3. Mapeo Normativos (one-pager: DORA compliance status)

Timeline recomendado:

- Presentación: 30 minutos (Slides 1-2, 4, 11, 13, 15)
- Q&A: 15 minutos
- Decision: 5 minutos

Presentación Structure (30 min):

0-2 min: Slide 1 (Portada)
2-5 min: Slide 2 (Agenda) + Slide 3 (Contexto regulatorio)
5-10 min: Slide 4 (IGM Dashboard: 3.0/5.0)
10-15 min: Slide 11 (ROI/ROSI: 203% ROSI; €1.6M ALE reduction)
15-20 min: Slide 12 (Roadmap: Fases 1-3; €910K presupuesto)
20-25 min: Slide 13 (Recomendaciones: 5 acciones inmediatas)
25-30 min: Q&A + decisión

Decision requested:

Motion 1: "Autorizar inversión €460K Fase 1 (Q1-Q2 2026)"
Motion 2: "Delegar supervisión CRO + CIS0; reporte trimestral"
Motion 3: "Establecer IGM 3.8 como target Q4 2026"

TIMELINE DE IMPLEMENTACIÓN (6 MESES)

Mes 1 (Enero 2026): Planificación y Setup

Semana 1:

- ☐ CISO workshop: GQM + PRAGMATIC introduction (2h)
- ☐ Governance: Asignar responsables (CISO, CRO, Compliance)
- ☐ Distribuir Kit documentos (6 PDFs a stakeholders)

Semana 2:

- ☐ Audit interno: Estado actual ciberseguridad
- ☐ Crear asset inventory (sistemas, datos, criticidad)
- ☐ Identificar gaps vs 15 indicadores

Semana 3:

- ☐ Data gathering: SIEM logs, tickets, scanning reports
- ☐ Interview key personas (SOC lead, asset owner, vendor mgr)

Semana 4:

- ☐ Primer cálculo IGM (baseline)
- ☐ Presentar board: "IGM 3.0/5.0; roadmap propuesto"
- ☐ Aprobar Fase 1 presupuesto (€460K)

Mes 2-3 (Feb-Mar 2026): Fase 1 Implementación

Feb:

- ☐ SIEM deployment (6 semanas)
- ☐ Alert rules configuration (200 rules)
- ☐ FAIR training (40h for analysts)
- ☐ Vendor assessments (5 pending)

Mar:

- ☐ Incident automation (notification workflow)
- ☐ Vulnerability scanning (automated schedule)
- ☐ TLPT contract (red team kickoff Q2)
- ☐ Governance policy update (Mar 31 deadline)

Mes 4 (Abril 2026): Fase 1 Completion + Fase 2 Start

Apr:

- ☐ SIEM tuning: MTTD target <15 min (achieved May 1)
- ☐ IGM re-assessment: Expect +0.3-0.5 improvement
- ☐ Fase 2 initiation: Encryption roadmap, BC testing
- ☐ CRO reporte: "Fase 1 on-track; IGM 3.3 expected May"

Mes 5 (May 2026): Fase 2 + Supervisory Prep

May:

- ☐ Encryption implementation (50% complete)
- ☐ BC/DR testing: Site activation
- ☐ TLPT execution ongoing
- ☐ IGM target: 3.5/5.0 by May 31
- ☐ Board update: "Fase 2 50% complete; MTDD <15 min achieved"

Jun:

- ☐ Fase 2 completion
- ☐ TLPT findings (red team report)
- ☐ Supervisory readiness planning
- ☐ IGM re-assessment: 3.5 expected

Mes 6 (Jun-Ago 2026): Fase 3 + Supervisory Audit Prep

Jul:

- ☐ Fase 3 initiation: FAIR quantification, GRC platform, Board dashboard
- ☐ TLPT remediation (50%+)
- ☐ Documentación centralizada (evidencia packa para supervisors)

Ago:

- ☐ Mock audit (interno)
- ☐ Supervisory preparation
- ☐ IGM target: 3.8/5.0
- ☐ Final board update before audit Q3

Sep-Oct:

- ☐ SUPERVISORY AUDIT (CNMV/Banco de España)
- ☐ Documento presentación de evidencia

FAQ: PREGUNTAS FRECUENTES

P: ¿Cuánto tiempo toma implementar todo el kit?

R:

- Lectura documentación: ~8-10 horas
- Adaptación institución: ~40-60 horas
- Implementación técnica: ~6 meses (depende de baseline)
- Resultado: IGM 3.0 → 3.8 en 6 meses típico

P: ¿Necesitamos herramientas adicionales?

R: Kit es "standalone" pero recommends:

- Excel (ya tienen)
- PowerPoint (ya tienen)
- SIEM (si no tienen, recomendamos Splunk/ELK) - €50-150K
- Vulnerability scanner (Qualys/Nessus) - €30-60K
- Incident management system (Jira/ServiceNow) - ya tienen típico

P: ¿Es obligatorio hacer todos 15 indicadores?

R: No. Priorizar conforme:

1. PRAGMATIC score (≥ 4.5 primero)
2. DORA Article criticidad
3. Recursos disponibles
4. Presupuesto

Mínimo recomendado: 9 indicadores core (MTTD, Patch, Incidents, TLPT, Contracts, etc.)

P: ¿Qué pasa si no pasamos auditoría supervisora?

R: Kit incluye "supervisory remediation" de bajo riesgo:

- MTTD < 15 min: Implementable 2-3 meses via SIEM tuning
- Patch rate: Implementable 1-2 meses via automation
- Vendor coverage: Aceleración due diligence 1 mes
- TLPT: Obligatorio pero timing flexible (bienal)

Riesgo bajo si roadmap se mantiene.

P: ¿Cuánto cuesta implementar?

R: Breakdown típico:

- SIEM: €50-150K (setup + 2 años licenses)
- TLPT (red team): €150-250K bienal
- Scanning tools: €30-60K
- TPRM platform: €50-80K
- Staff/training: €50-100K
- Contingency: €100-150K

Total rango: €430-790K (matching roadmap €910K estimado)

P: ¿Hay formato de agencia/consultoría?

R: Kit fue diseñado para "homegrown" implementación pero adaptable:

- CISOs con equipo en-house: 100% applicable
- Sin equipo técnico: Considerar partner Tier 1 (Deloitte, KPMG, Accenture)
- Parcial outsourcing: TLPT (siempre externo) + SIEM (consultor) + operacional (interno)

P: ¿Cómo manejamos "legacy systems" que no cumplen?

R: Kit incluye "exception management":

1. Documentar legacy systems (qué son, por qué existen)
2. Crear remediation plan con timeline
3. Justificar: "Plan de modernización 2026-2027"
4. Supervisors aceptan si evidencia de progreso

Ejemplo: 15 legacy servers sin scanning – Reemplazo timeline 18 meses

P: ¿Compartimos datos con supervisores antes auditoría?

R: Best practice (España):

- Proactivo: Enviar PowerPoint + evidencia pack 4 semanas antes audit
- Transparencia: "Aquí están nuestros scores; aquí están nuestras gaps; aquí nuestro plan"
- Credibilidad: CNMV valida más si honestidad demostrada

No recomendamos "sorpresas" con auditoría.

TROUBLESHOOTING

Problema: "MTTD metric está 18 min, target 15 min - ¿qué hacer?"

Solución:

1. Revisar "Indicador 1: MTTD" en Matriz PRAGMATIC
2. Root cause: ¿Detection rule delays? ¿SIEM tuning? ¿Analyst response?
3. Action: SIEM rules tuning + ML behavioral analytics
4. Target: Achievable May 2026

Problema: "Supervisores preguntan por FAIR methodology - no tenemos"

Solución:

1. Revisar "Pilar 2 - Riesgos TIC" en PowerPoint Slide 6
2. FAIR es optional pero recomendado Art. 6 DORA
3. Plan: Training Feb 2026; implementation Mar-Apr 2026
4. Interim: Usar ALE simplificado (modelo descrito Excel Hoja 3)

Problema: "No tenemos presupuesto €910K - ¿reducir?"

Solución:

1. Priorizar Fase 1 (€460K, Score ≥ 4.5)
2. Diferir Fase 2-3 a 2027 (€320K + €130K)
3. Phased approach: 2026 = Critical; 2027 = Enhancements
4. Risk: Auditoría puede requerir acceleration si gaps críticos

Problema: "Datos inconsistentes entre SIEM y tickets - qué es verdad?"

Solución:

1. SIEM es "source of truth" para detección
2. Tickets son "source of truth" para remediación
3. Timestamp discrepancy típica 5-15 min (acceptable)
4. Validación: Retesting post-remediación

CONTACTO Y SUPPORT

Preguntas sobre Kit:

Email: [compliance@institución.es]

Responsable: Compliance Officer o CISO

Timeframe respuesta: 24-48 horas

Escalations:

- Metodología GQM/PRAGMATIC: CISO
- Presupuesto/ROI: CFO
- Supervisory compliance: Compliance Officer
- Auditoría supervisora: CRO + CISO + Compliance

ANEXOS

Anexo A: Glosario de Términos

ALE:	Annualized Loss Expectancy
DORA:	Digital Operational Resilience Act (EU 2022/2554)
GQM:	Goal-Question-Metric methodology
IGM:	Índice de Gestión de Madurez (1-5 escala)
MTTD:	Mean Time To Detect (minutos)
MTTR:	Mean Time To Remediate (horas)
PRAGMATIC:	9 criterios de calidad de métricas
ROSI:	Return on Security Investment (%)
RTS:	Regulatory Technical Standards (EBA/ESMA/EIOPA)
SIEM:	Security Information and Event Management
TLPT:	Threat-Led Penetration Testing

Anexo B: Links Útiles

CNMV (España):	https://www.cnmv.es
Banco de España:	https://www.bde.es
DORA Regulation (EU):	https://eur-lex.europa.eu/eli/reg/2022/2554
EBA RTS:	https://www.eba.europa.eu/regulation-and-policy/
NIST CSF:	https://www.nist.gov/cyberframework
ISO 27001:	https://www.iso.org/standard/27001

Fin del README

Enero 2026 — Guía de Implementación Kit DORA+GQM+PRAGMATIC